

ISO 42001: A Management System for Governing AI Risk

Understand how ISO 42001's plan-do-check-act cycle, four risk layers, and high-level structure govern AI, and how it fits alongside the NIST AI RMF and the EU AI Act.

For security, compliance, and engineering leaders who need to figure out how to govern AI systems their organization builds or buys · 27 July 2026

The one- or two-page version: what matters, the topics it covers, and every term defined. Read the full lesson for the explanations and worked examples.

[Watch the source video](#)[Read the full lesson](#)[Read the condensed version](#)

What matters

- ✓ ISO 42001 is the AI-specific counterpart to ISO 27001: a certifiable management system for governing AI risk continuously, not a one-time checklist.
- ✓ ISO 42001 runs on the plan-do-check-act cycle: define AI policy and risk criteria, deploy with controls, monitor for bias and drift, then act on what you find.
- ✓ AI risk shows up in four distinct layers, data, model, system, and usage, and a control aimed at one layer does not fix the others.
- ✓ ISO 42001 follows the standard ISO high-level structure, with sections for context, leadership, planning, support, operation, evaluation, and improvement.
- ✓ The NIST AI Risk Management Framework is voluntary guidance describing what good AI risk management looks like; it has no certification mechanism.
- ✓ The EU AI Act is binding law with a tiered risk structure (unacceptable, high, limited, minimal) and enforceable penalties for noncompliance.
- ✓ NIST, ISO 42001, and the EU AI Act are complementary layers, not competing choices: risk-modeling guidance, certifiable governance, and legal compliance each cover a different need.
- ✓ Treating AI governance as a one-time checkbox, or skipping it entirely, both leave an accountability gap; building it into an ongoing management system is what lets AI scale safely.

What it covers

01 The Governance Gap: Why AI Needs a Management System 0:00

When an algorithm denies a loan with no explanation and no accountable owner, that is a governance failure, not just a technology failure.

02 ISO 42001: An AI Management System Built on ISO 27001's Foundation 0:44

ISO 42001 applies the same management-system concept that ISO 27001 uses for information security, but aimed at AI risk instead.

03 The Plan-Do-Check-Act Cycle and Risk-Based Thinking 1:25

ISO 42001 runs on plan-do-check-act, a repeating cycle, and scales its controls to how much risk a given AI system actually poses.

04 Four Layers of AI Risk: Data, Model, System, and Usage 2:12

ISO 42001 splits AI risk into four layers, and a control that fixes one layer does not automatically fix the others.

05 Context and Leadership: Scoping AI and Assigning Ownership 2:59

ISO 42001 opens by defining which AI systems are in scope and naming who is accountable for them; without an owner, nothing else in the standard happens.

06 **Planning, Support, Operation, Evaluation, and Improvement** 3:44

The remaining five sections of ISO 42001 turn risk assessment and policy into day-to-day operating practice, and close the loop when something goes wrong.

07 **Comparing ISO 42001, NIST AI RMF, and the EU AI Act** 5:53

NIST offers voluntary guidance, ISO 42001 offers a certifiable governance system, and the EU AI Act is enforceable law; they answer different questions.

08 **Complementary Layers: Building a Resilient AI Governance Stack** 7:58

NIST, ISO 42001, and the EU AI Act stack rather than compete, and organizations that build governance into an ongoing system scale AI faster and more safely than those that treat it as a checkbox or skip it entirely.

Glossary

ISO 27001 — The international standard for information security management systems (ISMS); it specifies how an organization establishes, implements, maintains, and continually improves a program for managing security risk.

Management system (ISO sense) — A defined, repeatable organizational process, establish, implement, maintain, improve, for running and governing a capability, as opposed to a fixed one-time checklist.

ISO High-Level Structure (HLS) — The common section skeleton, context, leadership, planning, support, operation, evaluation, improvement, shared across ISO management-system standards so they can be run together.

Explainability — The degree to which a model's output can be understood or justified in terms a human can follow, part of ISO 42001's model-risk layer.

Risk treatment plan — A documented decision for how each identified risk will be handled, mitigate, accept, transfer, or avoid, rather than an assumption that every risk must be eliminated.

EU AI Act — Binding European Union law regulating AI systems, using a tiered risk structure (unacceptable, high, limited, minimal) and carrying enforceable penalties for noncompliance.

ISO 42001 — The international standard for AI management systems (AIMS), the AI-focused counterpart to ISO 27001; it is auditable, certifiable, and built around continual improvement across an AI system's life cycle.

Plan-Do-Check-Act (PDCA) — A four-stage continuous improvement cycle: plan controls and policy, execute them, check the results against real-world performance, then act on what was found.

Bias drift — Gradual change in a model's fairness or accuracy characteristics over time as real-world data shifts away from what the model was trained or validated on.

Risk appetite and risk tolerance — Risk appetite is the amount and type of risk an organization is willing to pursue to reach its objectives; risk tolerance is the acceptable variation in outcomes it can withstand for a given risk.

NIST AI Risk Management Framework (AI RMF) — A voluntary framework from the U.S. National Institute of Standards and Technology offering flexible, non-certifiable guidance on what good AI risk management practice looks like.

Explanations are AI-generated. Check anything you intend to rely on.